



CYBER SECURITY INTERNSHIP

Mini Incident Response Plan

ZenKart Commerce — Phishing-Initiated Ransomware Incident

Framework Referenced: NIST Incident Response Lifecycle (NIST SP 800-61)

Prepared By:	Muhammad Maaz Afridi
Program:	VortexTech Cyber Security Internship Track
Module:	Week 4 of 4 — Advanced
Submission:	Mini Incident Response Plan

1. Scenario Overview

ZenKart Commerce is a fictional mid-sized e-commerce company with approximately 150 employees, operating an online storefront that processes customer orders and stores customer payment and shipping information.

What Happened

A member of the Customer Support team received an email that appeared to be a genuine customer complaint, with an attached file named “complaint_form.docx.” Opening customer attachments is a routine part of this employee's job, so the file was opened without suspicion. The document contained a malicious macro that (1) silently installed a credential-stealing malware payload on the employee's workstation, and (2) simultaneously displayed a fake “session expired – please log in again” prompt. The employee re-entered their corporate credentials into this fake prompt, handing the attacker a valid, working password in addition to the malware already installed.

Using the stolen credentials and the malware foothold, the attacker moved laterally across the internal network and deployed a ransomware payload, which encrypted files across multiple shared drives and internal servers.

Data at Risk

- Internal financial records and payroll files
- Shared drive containing archived customer order exports (names, emails, shipping addresses, partial payment records)
- Internal support tickets containing customer correspondence

2. Incident Response Plan (NIST Lifecycle)

The response below follows the six phases of the NIST Incident Response Lifecycle (NIST SP 800-61): Preparation, Detection & Analysis, Containment, Eradication, Recovery, and Lessons Learned.

Phase 1: Preparation

What should already be in place before an incident like this occurs:

- A documented Incident Response (IR) team with defined roles: IR Lead, IT/Security Analyst, Legal/Compliance Liaison, Communications Lead.
- Endpoint monitoring and email security tools (spam/phishing filters, attachment sandboxing) to catch malicious emails before delivery.
- Regular, tested offline/immutable backups of critical servers and shared drives.
- Mandatory security awareness training, including simulated phishing tests, for all employees — especially customer-facing roles that routinely open external attachments.

- Multi-factor authentication (MFA) enforced on all corporate accounts.
 - A written, rehearsed IR playbook so the team is not improvising during a real event.
-

Phase 2: Detection & Analysis

How the breach was realistically discovered — through multiple converging signals:

- An automated endpoint alert flagged unusual mass file-encryption activity on a shared drive.
- Multiple employees separately reported that shared files would not open, with filenames showing an unfamiliar extension.
- A ransom note file was found in an affected folder, explicitly demanding payment — confirming this was a deliberate attack, not a system fault.

Initial investigation steps taken by the security team:

- Confirm the alert is a true positive by checking affected file shares and server logs.
 - Trace the entry point via authentication logs, identifying the Customer Support employee's account as the likely patient zero.
 - Determine scope: which servers, drives, and accounts show signs of compromise or encryption.
 - Preserve logs and evidence for later forensic review before making major changes.
-

Phase 3: Containment

Short-term actions taken immediately to stop the spread:

- Disable the compromised Customer Support account and force an immediate password reset.
- Isolate affected servers and shared drives from the network to stop further encryption.
- Revoke and rotate any API keys, VPN tokens, or session credentials tied to the compromised account.
- Block the sender domain and related indicators of compromise (IOCs) at the email gateway and firewall.

Longer-term containment:

- Segment the network further to prevent lateral movement if the attacker attempts to pivot elsewhere.
-

Phase 4: Eradication

- Remove the malicious macro-based malware and any attacker-installed tools or backdoors from infected systems.

- Patch or reconfigure the email gateway/attachment-scanning rules that allowed the malicious document through.
- Conduct a full credential audit; force a password reset for all accounts that may have been exposed.
- Scan all endpoints — not just the ones known to be affected — to confirm no other systems were silently compromised.

Phase 5: Recovery

- Restore encrypted files from clean, verified offline backups rather than paying the ransom.
- Rebuild or reimage compromised servers from known-good images before reconnecting them to the network.
- Bring systems back online in stages, with heightened monitoring, rather than all at once.
- Confirm with the security team that no residual malicious activity is occurring before formally declaring the incident closed.

Phase 6: Lessons Learned (Post-Incident Review)

The post-incident review concluded the following:

- The absence of MFA on the compromised account was the single biggest factor that allowed the stolen password to be used successfully.
- Customer-facing roles that routinely open external attachments need more frequent, role-specific phishing awareness training, with simulated tests to measure improvement.
- Shared drives lacked sufficient network segmentation, allowing the ransomware to spread quickly once one account was compromised.
- The IR playbook worked, but communication to affected employees was slower than ideal and should be templated in advance for faster use.

3. Internal Communication Plan

Who is notified, and roughly when, during the incident:

Who	When	Purpose
IT / Security Team Lead	Immediately (0–15 min)	Triggers the incident response plan; assigns roles
CISO / IT Director	Within 30 minutes	Authorizes containment actions (isolating systems, disabling accounts)
Executive Leadership (CEO/COO)	Within 1–2 hours	Briefed on business impact and scope

Legal & Compliance Team	Within 4 hours	Assesses breach notification obligations under data protection laws
All Employees (internal memo)	Within 24 hours	Warned about the phishing campaign; told to report suspicious emails
Affected Customers / Regulators	As required by law (e.g., within 72 hrs where mandated)	Formal breach notification once scope is confirmed

4. Preventative Measures

Directly tied to the root cause of this scenario — a phished credential combined with malware, with no MFA in place, leading to uncontrolled ransomware spread:

- 1. Enforce Multi-Factor Authentication (MFA) on all accounts.** Even if a password is phished, MFA would have blocked the attacker from logging in with just the stolen credential.
- 2. Run regular, role-specific phishing-simulation training.** Customer-facing employees who routinely open external attachments are practiced at spotting fake forms, fake login prompts, and suspicious senders.
- 3. Segment shared drives and enforce least-privilege access.** Limiting how far a single compromised account can reach would have slowed or stopped the ransomware from spreading across the whole network.

Prepared by Muhammad Maaz Afridi — VortexTech Cyber Security Internship Track, Week 4 of 4 Submission.